

AI Risk & Governance Assessment

Enterprise AI Customer-Service Agent — Applying the NIST AI Risk Management Framework

Prepared by: Nisarg Kamble | AI Governance Portfolio, Project 2 of 5 | September 2026

1. Executive Summary

This assessment applies the NIST AI Risk Management Framework (AI RMF 1.0, NIST AI 100-1, published January 26, 2023) to a hypothetical deployment: an AI-powered customer-service agent for a fictional Indian fintech, Northstar FinTech Services Pvt. Ltd. (a fictional organization created for this exercise; any resemblance to a real company is coincidental). The NIST AI RMF is voluntary risk-management guidance, not law — applying it demonstrates a structured, defensible risk process but does not, by itself, satisfy any specific legal or regulatory obligation. Those obligations (discussed in Section 3) must be assessed separately. The assessment concludes with a governance recommendation of Approve with Conditions, contingent on the controls specified in Section 7.

2. Organization and AI Use Case

Northstar FinTech Services Pvt. Ltd. is a fictional Indian non-banking financial company (NBFC) offering personal loans and savings products through a mobile app. The organization is piloting an AI-powered conversational agent, built on a third-party large language model (LLM), to handle customer-service interactions: account balance queries, loan status updates, KYC document status, and general product questions. The agent is scoped to read-only account information retrieval and FAQ-style responses; it is not currently authorized to initiate transactions, alter account details, or approve/reject credit applications. This scope boundary is a deliberate risk-mitigation decision, not a technical limitation of the underlying model, and is treated as a control in Section 7.

3. Scope and Assumptions

This assessment covers the customer-service agent as described above; it does not cover Northstar's separate credit-decisioning models, which would require a distinct, higher-scrutiny assessment given their regulated nature.

As an Indian NBFC, Northstar is subject to specific, current RBI regulation on IT outsourcing, cybersecurity, and digital lending — treated as a separate compliance track from this NIST-based risk assessment:

- **RBI (NBFC — Outsourcing of IT Services) Directions, 2025** — in effect from 28 November 2025 for new IT outsourcing contracts, with existing contracts required to transition by 10 April 2026 or at renewal, whichever is earlier. Requires a board-

approved IT outsourcing policy, a central register of material outsourcing arrangements, and audit rights over vendors and sub-vendors.

- **RBI (NBFC — Cybersecurity, Technology Risk, Resilience and Assurance) Directions, 2026** — requires cyber-incident reporting on the RBI's DAKSH platform within 6 hours of detection, and prescribes governance responsibilities scaled to NBFC category.
- **RBI Digital Lending Directions, 2025** (issued 8 May 2025) — the consolidated framework governing Lending Service Provider (LSP) relationships; relevant context given Northstar's third-party-LLM dependency, though the customer-service agent itself does not originate loans.

India's Digital Personal Data Protection Act, 2023 (DPDP Act) is enacted law and has been formally in force in staged commencement since November 2025 (Data Protection Board established under notification G.S.R. 843(E), 13 November 2025). As of September 2026, the Act's substantive consent, notice, and breach-notification obligations are not yet operative — those are scheduled to come into force on 13 May 2027, with the Consent Manager framework separately scheduled for 13 November 2026. *(A Supreme Court challenge to the Act was pending as of August 2026, with notice issued but no interim stay granted — this does not currently change the commencement schedule above, but is worth monitoring given how this could move.)* This assessment treats DPDP compliance as a near-term, not yet fully binding, obligation that Northstar should prepare for ahead of the 2027 deadline, and distinguishes this explicitly from the voluntary NIST framework applied throughout this document.

This is an illustrative assumption and is not presented as an externally verified fact: all internal Northstar policies, team structures, and prior incidents referenced below are fictional constructs created for this exercise.

4. GOVERN

Govern is the cross-cutting NIST AI RMF function; it establishes the accountability structure that makes Map, Measure, and Manage repeatable rather than one-off exercises.

- **Governance structure:** an AI Governance Committee (cross-functional: Risk, Legal/Privacy, Technology, Customer Experience, Internal Audit) has approval authority over new AI use cases before pilot and before general release.
- **Accountability:** a named Business Owner (Head of Customer Experience) is accountable for the agent's day-to-day performance; a named AI Risk Owner (within the Risk function) is accountable for ongoing risk monitoring and escalation.
- **Policy:** Northstar's Responsible AI Policy (see Project 3 of this portfolio) defines the risk-classification tiers referenced in Section 6 below.
- **Escalation:** any customer-reported harm, factual error with financial consequence, or suspected security incident involving the agent is escalated to the AI Risk Owner within 24 hours under Northstar's incident-management process (Section 7).
- **Third-party oversight:** because the agent is built on a third-party LLM, Govern requires a documented vendor-governance relationship (see Project 4 of this portfolio, the vendor risk questionnaire) rather than treating the vendor's assurances as self-verifying.

5. MAP

5.1 Intended Purpose and Stakeholders Intended purpose: reduce customer wait times and deflect routine queries from human agents. Stakeholders: retail customers (including first-time digital-finance users), Northstar customer-service staff (whose workflow changes), RBI and other regulators, and Northstar’s Board and shareholders (reputational and financial exposure).

5.2 Data and System Components The agent ingests customer account data (read-only), a product FAQ knowledge base, and conversation history within a session. It depends on a third-party LLM API (external dependency) and Northstar’s internal customer data platform. Conversation logs are retained for quality review and dispute resolution.

5.3 Foreseeable Risks and Failure Modes

- **Hallucination:** the agent generating plausible-sounding but factually incorrect information about loan terms, fees, or account status — distinct from a simple factual inaccuracy sourced from stale data, since hallucination originates in the model’s generation process itself rather than in the underlying data.
- **Prompt injection:** a customer (or a malicious actor posing as a customer) crafting inputs designed to manipulate the agent into ignoring its scope restrictions or revealing system instructions.
- **Privacy:** exposure of one customer’s PII to another user through a session-handling defect, or inclusion of sensitive personal data in logs accessible to a broader internal audience than necessary.
- **Over-reliance / insufficient human oversight:** customers or staff treating agent output as authoritative for decisions (e.g., loan eligibility) it was not scoped or validated to make.
- **Model drift:** degradation in response accuracy as products, fees, or policies change without corresponding updates to the agent’s knowledge base.

5.4 Regulatory Considerations (Mapped, Not Assessed for Compliance Here) The RBI Outsourcing Directions, 2025 and the RBI Digital Lending Directions, 2025 are directly relevant given the third-party LLM dependency and the financial-services context; a separate RBI-compliance review (outside NIST AI RMF’s scope) is required and is flagged here as a dependency, not resolved by this document.

6. MEASURE

The table below assesses identified risks using a three-level qualitative scale (Low / Medium / High for Likelihood and Impact; combined into an overall Risk Level). This is a qualitative judgment methodology, not a statistically derived score, and is documented as such rather than presented as a precise numerical output.

Risk	Likelihood	Impact	Overall
Hallucination (incorrect loan/fee/account	Medium	Medium	Medium

Risk	Likelihood	Impact	Overall
info)			
Prompt injection	Medium	Medium	Medium
Privacy exposure (PII leakage)	Low	High	Medium
Over-reliance on unscoped output	Medium	Medium	Medium
Model drift	Medium	Low	Low–Medium
Unauthorized transaction initiation	Low*	Severe	Medium

*Impact is assessed based on potential financial loss to customers, regulatory exposure, and reputational harm; “Severe” impact (unauthorized transaction initiation) reflects that this risk is currently mitigated primarily through scope restriction (the agent cannot initiate transactions) rather than through detection — meaning its likelihood rating depends on that scope boundary holding, which is itself a control to be tested (Section 7).

7. MANAGE

7.1 Preventive Controls

- Scope enforcement: the agent’s action space is restricted at the system-design level (read-only; no transaction capability) rather than relying solely on prompt-level instruction.
- Input/output filtering: automated screening for prompt-injection patterns and for outputs that resemble transaction confirmations or credit decisions.
- Data minimization: the agent is provisioned access only to the customer data fields required for its defined functions, not full account records.
- Pre-deployment testing: adversarial testing (including prompt-injection red-teaming) and accuracy benchmarking against a curated question set before general release.

7.2 Detective Controls

- Ongoing monitoring: sampled conversation review for hallucination rate, escalation-appropriateness, and PII-handling compliance.
- Logging and audit trail: all agent interactions logged with sufficient detail to reconstruct a disputed interaction, with access to logs restricted on a need-to-know basis. (Incident-reporting timelines must accommodate the RBI’s 6-hour DAKSH reporting requirement under the 2026 Cybersecurity Directions — see Section 3.)
- Anomaly detection: alerting on unusual patterns (e.g., a spike in a single user’s message volume consistent with automated prompt-injection attempts).

7.3 Corrective Controls

- Human escalation path: any query outside the agent’s defined scope, or any customer expression of dissatisfaction, routes to a human agent — this is human-in-the-loop

design (a specific workflow mechanism) implementing the broader principle of human oversight (the accountability structure that requires it).

- Incident response: a defined process (Section 4) for containment, customer remediation, and root-cause documentation when a factual error or privacy exposure occurs.
- Version and knowledge-base management: a change-control process ensuring the agent's product/fee knowledge base is updated in lockstep with actual policy changes, to limit drift-related risk.

8. Residual Risk

Even after the controls above, residual risk is not eliminated. Hallucination risk cannot be reduced to zero for any LLM-based system; the controls reduce likelihood and limit impact (via human escalation) rather than removing the risk. Similarly, third-party LLM dependency introduces residual vendor-risk exposure that Northstar cannot fully control internally — this is why vendor governance (Project 4) is treated as a linked, ongoing requirement rather than a one-time procurement check. These residual risks should be explicitly accepted, not ignored, by the AI Governance Committee as part of the deployment decision.

9. Governance Decision

Recommendation: Approve with Conditions.

The use case, as scoped (read-only information retrieval, no transaction authority), presents a manageable risk profile provided the preventive and detective controls in Section 7 are implemented before general release, and provided the RBI outsourcing/digital-lending compliance review (Section 5.4) is completed as a parallel, non-optional workstream. This is a risk-management judgment under the NIST AI RMF; it does not constitute a legal compliance determination, which requires separate review by Northstar's Legal and Compliance functions against RBI and DPDP Act obligations.

10. Implementation Roadmap

Short-term (0–3 months)

- Complete adversarial/red-team testing and finalize scope-enforcement controls
- Stand up conversation-log monitoring and escalation-tracking dashboards

Medium-term (3–9 months)

- Complete RBI outsourcing/digital-lending compliance review (against the 2025/2026 Directions named in Section 3)
- Establish recurring (e.g., quarterly) subgroup and accuracy performance review cadence

Long-term (9+ months)

- Begin DPDP Act 2027-deadline readiness work (consent and notice mechanisms) ahead of the Act's substantive obligations coming into force

- Evaluate whether expanded agent capabilities (e.g., limited transaction actions) would require a new, higher-scrutiny Map/Measure cycle

11. Limitations

- This assessment is illustrative and uses a fictional organization; it does not reflect an actual Northstar risk posture, vendor relationship, or incident history.
 - Qualitative Likelihood/Impact ratings in Section 6 reflect reasoned judgment for this exercise, not empirical incident data, and would need to be recalibrated against real monitoring data post-deployment.
 - This document applies NIST AI RMF as a risk-management process; it explicitly does not constitute legal advice or a compliance certification under RBI, DPDP, or any other regulatory regime.
 - The DPDP Act's commencement schedule (Section 3) was subject to a pending Supreme Court challenge as of August 2026; this document reflects the schedule as it stood at time of writing and should be rechecked before relying on it after that date.
-

References

- National Institute of Standards and Technology. (2023). *AI Risk Management Framework (AI RMF 1.0)*. NIST AI 100-1.
- Reserve Bank of India. *RBI (NBFC — Outsourcing of IT Services) Directions, 2025* (effective 28 November 2025; transition for existing contracts by 10 April 2026).
- Reserve Bank of India. *RBI (NBFC — Cybersecurity, Technology Risk, Resilience and Assurance) Directions, 2026*.
- Reserve Bank of India. *RBI Digital Lending Directions, 2025* (issued 8 May 2025).
- Ministry of Electronics and Information Technology, Government of India. *Digital Personal Data Protection Act, 2023*, and *DPDP Rules, 2025* (notified 13 November 2025, G.S.R. 843(E)) — staged commencement status as of September 2026.

Note on evidence verification: Every source above was independently checked against a live web search in September 2026. The DPDP Act commencement timeline was already accurately stated in the original draft and required no correction. The RBI reference was upgraded from a generic description to the three specific, named, dated regulations above.